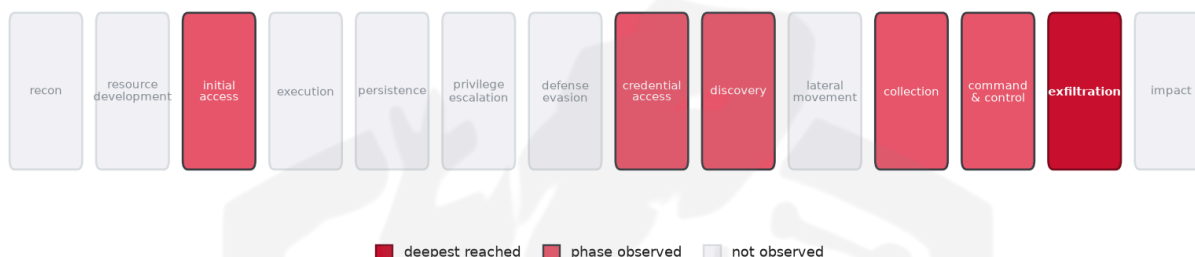


THREAT REPORT: REF7707 ESPIONAGE AND CRYPTOCURRENCY FRAUD CAMPAIGN

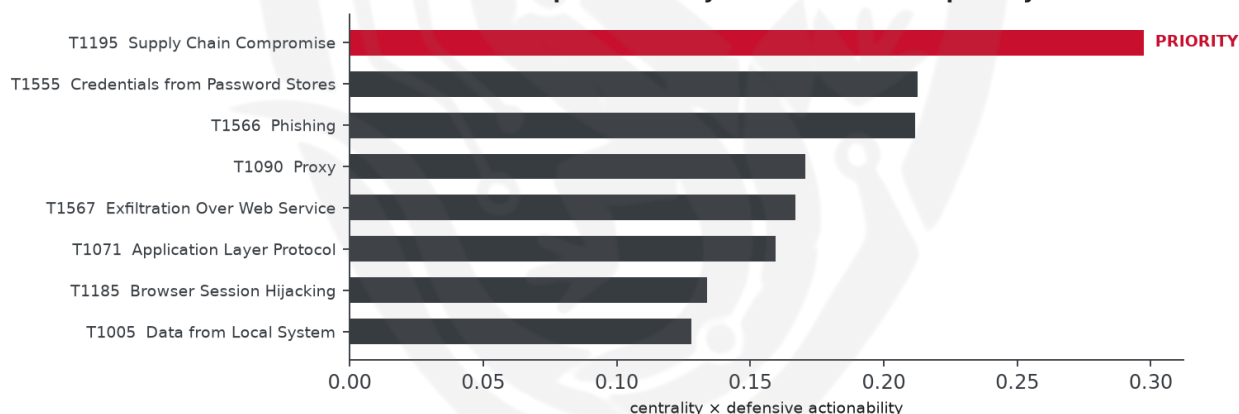
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The source attributes this activity to REF7707, a China-based hackers-for-hire group, which has been staging espionage attacks alongside a cryptocurrency fraud business. The group has been targeting various sectors in the United States of America, including Government, Defense, Finance, and others. The threat actor's use of multiple malware families, including Antino, ClientKing, and others, has allowed them to exploit vulnerabilities and steal sensitive information. Priority should be given to verifying software supply chain integrity to prevent further compromise.

Threat Overview

REF7707, the observed threat actor, has been utilizing a range of malware families, including Antino, ClientKing, PDF Viewer, XG-Web, Rekoobe, and TinySHell, to target organizations in the United States.

The central vulnerability exploited is currently unknown, but the group's techniques include screen capture, system owner discovery, and web session cookie theft. The victimology indicates a broad range of targeted sectors, including Government, Defense, Finance, and others.

Attack Chain and Priority Control

The threat actor's attack chain involves a range of techniques, including screen capture, system owner discovery, and web session cookie theft, ultimately leading to exfiltration over web services. The priority technique is T1195 Supply Chain Compromise, which serves as a chokepoint in the attack chain. To mitigate this threat, the priority control is to Verify software supply chain integrity (signing, SBOM); pin and monitor third-party dependencies and update channels.

Infrastructure and Corroboration

The malicious infrastructure associated with REF7707 has been observed to be hosted on USCloud Inc. While there are no malware families corroborated by abuse.ch, and no indicators have been flagged with high confidence by AbuseIPDB, this information provides additional context to the threat actor's operations, attributed to third-party sources such as AbuseIPDB and abuse.ch.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1113 Screen Capture
- T1033 System Owner/User Discovery
- T1539 Steal Web Session Cookie
- T1114 Email Collection
- T1119 Automated Collection
- T1082 System Information Discovery
- T1071 Application Layer Protocol
- T1005 Data from Local System
- T1195 Supply Chain Compromise
- T1555 Credentials from Password Stores
- T1567 Exfiltration Over Web Service
- T1185 Browser Session Hijacking
- T1090 Proxy
- T1083 File and Directory Discovery
- T1057 Process Discovery
- T1566 Phishing
- T1573 Encrypted Channel
- T1056 Input Capture
- T1132 Data Encoding

- T1189 Drive-by Compromise

Analytical Scores

- Priority technique (graph chokepoint): T1195 Supply Chain Compromise (centrality 0.2973).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4226; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Windigo	0.4226
Winter Vivern	0.3727
Stealth Falcon	0.3591
Inception	0.3451
Dark Caracal	0.3078

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	38[.]12[.]1[.]47	AbuseIPDB 0% (US) · AS402169 US Cloud Inc
IP	103[.]87[.]9[.]62	
IP	43[.]246[.]208[.]236	
IP	43[.]246[.]208[.]179	
IP	219[.]76[.]254[.]184	

Type	Indicator	Context
IP	103[.]27[.]77[.]10	
IP	195[.]172[.]120[.]227	
Domain	juliangip[.]com	
Domain	sttlink[.]com	
Domain	bieqiang[.]xyz	
Domain	dm1[.]longmingdns[.]com	
Domain	dm2[.]longmingdns[.]com	
Domain	www[.]jkskhei[.]com	
Domain	ns1[.]jkskhei[.]com	
Domain	fonts[.]tarotfree101[.]top	
Domain	fonts[.]chrone[.]com	
Domain	robot[.]javbliud[.]com	
Domain	microsoft-flash[.]com	
Domain	www[.]wps-cn[.]com	
Domain	www[.]f1ash[.]org[.]cn	
Domain	eastus2[.]wac-azure[.]com	
Domain	mailbycloud[.]com	

Type	Indicator	Context
Domain	dns[.]wizkidblogger[.]com	
Domain	eoycqqcyix[.]com	
Domain	haoxizhiye[.]com	
Domain	jkskhei[.]com	
Domain	tkstream123[.]com	
Domain	usnbweb[.]mobi	
Domain	aws[.]baidupi[.]top	
Domain	xg[.]browser[.]fake[.]top	
URL	hxxps://fonts[.]chrone[.]com/dist/js/12[.]qgfvjzvs[.]chunk[.]js	
URL	hxxps://microsoft-flash[.]com/download/Adobeinstall[.]exe[.]	
Hash	e6ff096a0562c0042b09d250bd60272ffcd8d72bd95c563842acf765a8dc8bcf	
Hash	01b5c6acb20e41799a0e96d9d1d6e1c44791883706b6285e874fcb15cc93b31a	
Hash	e809da86bd81463347fa7f922d3e088755a94a331889d32acb55aa8f57778a34	
Hash	f1ef5fe4c0cdcff13cc750c867728b89719f81437bdc49041edd1ae1f3edb4e8	
Hash	e2eb7703047b37b28dc34e6990205d758a2454b39bc655b460606745fadcb530	
Hash	e7e3b0bcd6798634adf8b49d305f3a7b7682e4b76db549682a183c5a186df4bb	
Hash	09ef7c736bccfafefc44d9910d499173b88063b73b221fc0dc9e9105107e5cff	

Type	Indicator	Context
Hash	c11714f9fe2df1ca906585c81498cd77f5ec05b132aab73fa3a71 d71d71e42cc	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1195 Supply Chain Compromise (initial-access)
- **Observed here:** T1195 Supply Chain Compromise was the initial-access control point; blocking a means-of-entry rarely stops a determined actor, so the pivot projects forward to the execution stage they must still reach.
- **Projected pivot:** T1053 Scheduled Task/Job (execution)
- **Basis:** of the 10+ groups that use Supply Chain Compromise, this pairing runs 2.7x above base rate, a disproportionately-coupled move rather than the obvious one.

The adversary, REF7707, could pivot to utilizing T1053 Scheduled Task/Job to maintain persistence and evade detection, as this technique allows them to blend their malicious activities with legitimate system tasks, potentially exploiting the trust associated with scheduled tasks to execute their payloads. This technique may be particularly appealing to REF7707 as it enables them to execute commands or scripts at specific times or intervals, which could be used to re-establish a foothold or move laterally within the network. To counter this potential move, the defensive control would involve alerting on new scheduled tasks (Event ID 4698), restricting schtasks/at to admins, and baselining legitimate task creators.

Also plausible (same tactic): T1203 Exploitation for Client Execution (n=7, lift 2.6), T1569 System Services (n=3, lift 2.7)

Detection and hardening for the pivot (T1053 Scheduled Task/Job)

- **Telemetry:** Windows Security (Object Access audit); Microsoft-Windows-TaskScheduler/Operational; Sysmon
- **Detect:**
 - Security 4698 (task created), 4702 (updated), 4700/4701 (enabled/disabled), 4699 (deleted)
 - TaskScheduler/Operational 106 (registered), 140 (updated), 141 (deleted)
 - Sysmon 1 for schtasks.exe and at.exe; Sysmon 11 for writes under C:\Windows\System32\Tasks\
- **Harden:**
 - Restrict schtasks/at to administrators; disable the legacy at.exe
 - Baseline the legitimate task creators and alert on anything outside it
- **MITRE:** M1047 Audit, M1028 Operating System Configuration, M1026 Privileged Account Management · DS0003 Scheduled Job, DS0009 Process, DS0022 File